Handoff 53: Secrets and personal data in the public history

Date: 2026-11-09 (America/Toronto)
Written by: Claude Code (implementer), in a separate git worktree
For: the human maintainer, and ChatGPT or Claude chat (reviewer) without repository access
Status: **in_review**: one pull request (#61), documentation only, not merged. **Nothing to rotate. History not rewritten.**

> **How to use this file:** it is the whole report. No secret value is printed in it, and none was found.

Run plan details

Field	Value
Request	Run 2 of the master run, part A1: "Public-repository safety", 2026-11-09
Base	`main`, at `ba4ccdf` (after #60)
Part 2 boxes relied on	**None** (all still empty)
Branch and worktree	`sec/history-scan`, `../python-academy-scan`

1. Answer first

Nothing real was found that needs rotating. No token, client secret, private key, database password, session secret or `.env` file with values has ever been committed, on any branch. Two things are public that you may want to know about (section 4): the Google email addresses in commit authorship, and four Render resource IDs in `DEPLOYMENT.md`. Neither is a credential.

2. What was scanned

Scope	How
Every commit on every branch and tag, local and remote (`git log --all`): 186 non-merge commits, 58 remote branches, 0 tags, plus the one local-only branch	Both tools below
Commit metadata (author and committer names and emails)	`git log --all --format`
Every file ever added, by name	`git log --all --diff-filter=A --name-only`

Not scanned, because they are not in git: untracked files in the main folder (`MASTER-RUN.md`, `design-prototype/`, `momentum/` and others), GitHub issue and PR text, and Render or Google settings.

3. Tools

Tool	Version	How it was obtained	Dependency added?
gitleaks	8.21.2, darwin arm64	The release archive from GitHub, checked against the release's `checksums.txt` (SHA-256 `cad3de5d…6502`, matched), unpacked into the session's scratch folder	**No.** Nothing was added to the repository or installed on the machine. It runs offline against the local clone
Pattern search	`grep -E` over the full patch of every commit (`git log --all -p`, 5.2 MB)	Built in	No

gitleaks ran as `gitleaks git --log-opts="--all" --redact`: 184 commits scanned (the other two have no diff), **1 finding**. Its report was kept outside the repository and not committed.

Patterns searched, and what they found

Looking for	Pattern (short)	Hits	What they are
Google OAuth client secret	`GOCSPX-`	0	
Google OAuth client ID	`apps.googleusercontent.com`	0	
Google API key	`AIza…`	0	
Render API key	`rnd_…`	0	
Private keys	`BEGIN … PRIVATE KEY`	0	
GitHub, OpenAI, Slack tokens	`ghp_`, `github_pat_`, `sk-…`, `xoxb-`	0	
Session or client secret with a value	`SESSION_SECRET=…`, `CLIENT_SECRET=…`	0	`.env.example` has them empty, as it should
Database URL with a password	`postgres://user:pass@`	1	CI's throwaway test database on `localhost` (`.github/workflows`), which exists only inside each CI run
Long quoted value assigned to `token`, `secret`, `password`, `api_key`		3	Test fixtures: an expected-output marker, a deliberately wrong signing key for a test, and a fake learner story

Looking for	Pattern (short)	Hits	What they are
Files named `.env`, `*.pem`, `*.key`, `credentials`, `client_secret`		1	`.env.example`, with empty values only
`ADMIN_EMAILS` with a real address		0	
Email addresses in file contents		41 kinds	**All** `@example.com` **or** `@school.example.org` test addresses, plus Python decorators the pattern also matches (`@pytest.fixture`)
Phone numbers		1	Coordinates in an SVG path
Render resource IDs	`srv-`, `dpg-`, `exs-`	4	See section 4.2

4. What is public, and what to do

4.1 Email addresses in commit authorship (personal data, not a secret)

Every commit records its author's email. Three are personal Gmail addresses, shown here with only the first letter:

Author name on commits	Email	Commits
`Lucasdt416-design`, `lucasdt416-design`, `Lucas-Thomas`	`l…@gmail.com` (yours)	229
`torontojohn`	`j…@gmail.com`	21
`dependabot[bot]`	a GitHub no-reply address	3

Anyone can read these now that the repository is public. Removing them would mean rewriting history, which you said not to do, and copies may already exist. **Recommended, not yet confirmed:** for future commits, turn on GitHub → Settings → Emails → "Keep my email addresses private" and "Block command line pushes that expose my email", and set `git config --global user.email` to the `…@users.noreply.github.com` address GitHub shows there. Tell torontojohn the same applies to theirs.

4.2 Render resource IDs in `DEPLOYMENT.md` (gitleaks' one finding)

Lines 9 to 12 of `DEPLOYMENT.md` name the Render blueprint, the two services and the database by their Render IDs. gitleaks flagged the API service line as a "generic API key". **These are identifiers, not credentials:** using them needs a signed-in Render account or a Render API key, and none is in the repository. Nothing to rotate. **Recommended, not yet confirmed:** leave them; if you would rather not publish them, replace the four lines with "see the Render dashboard" in a later docs PR (the old values stay in history either way).

4.3 Nothing from Google

No Google client ID, client secret, API key or refresh token appears anywhere in the history. The OAuth settings live only in Render's environment, as `DEPLOYMENT.md` says.

5. What could not be checked

- **Render's and Google's own settings and logs.** Not visible from the repository (and out of bounds for this run).
- **GitHub issue, PR and comment text,** and Actions logs. Not part of git history. CI logs show test output only; no secret is set in the workflows.
- **Secrets in a form the tools don't know.** gitleaks' rules plus the patterns above cover the services this project uses; an unusual secret written in plain words would be missed.
- **Forks and clones** made since the repository went public. Not visible.

6. How it was tested

Check	Result
Downloaded archive's SHA-256 against the release checksums	Matched
gitleaks on all refs	1 finding (section 4.2)
Each pattern above, on the full patch	Counts in section 3; every hit read by hand
That the report holds no secret	No secret found; the report was kept out of the repository anyway

Documentation only, so no deliberate-break checks; nothing in the app changed.

7. Questions for you

1. **Commit emails:** switch to GitHub's no-reply address for future commits? *Recommended, not yet confirmed: yes.*
2. **Render IDs:** keep them in `DEPLOYMENT.md`? *Recommended, not yet confirmed: keep; they are not credentials.*
3. **Ongoing scanning:** add a gitleaks check to CI? It would need a new pinned action or a downloaded binary in the workflow, so it needs your yes first (master run section 1.6). *Recommended, not yet confirmed: yes, pinned by commit like the other actions, scanning only new commits.*

8. For the docs sync

File	Change
`backlog.md` section 1	Row 53: this scan, PR #61, handoff 53, documentation only
`decision-log.md`, open questions	The three questions above

9. Next concrete action

Read section 4; merge when you are happy. Nothing else is urgent.

10. Removing the worktree safely

From the **main** folder, after this PR is merged:

```
cd /Users/DEV/Projects/python-academy
git -C ../python-academy-scan status --short   # expect nothing
git worktree remove ../python-academy-scan
git worktree prune
git branch -d sec/history-scan
```